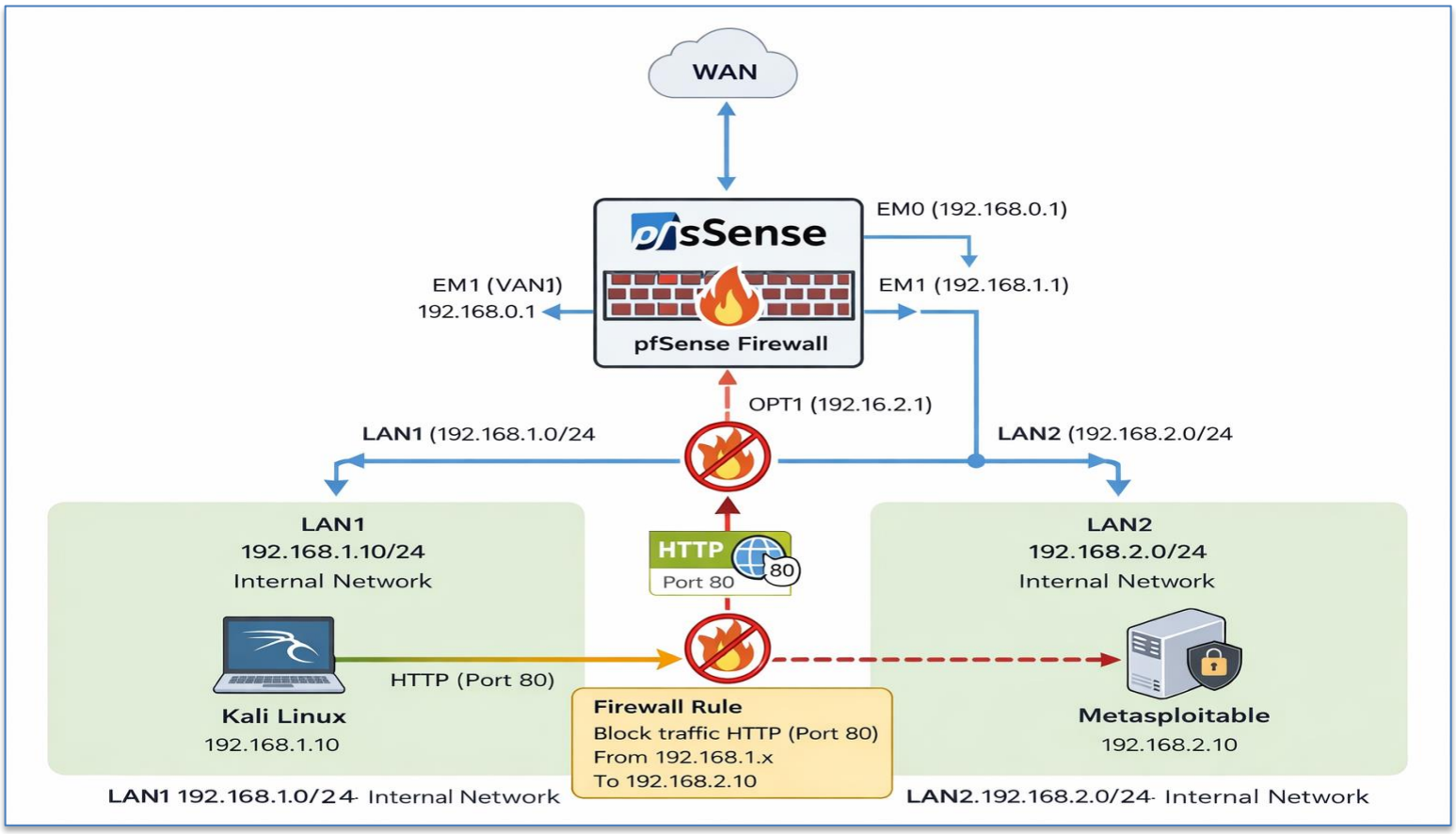
Report tecnico di implementazione

Segmentazione di rete con pfSense, controllo accessi verso DVWA e mitigazione dell'esposizione dei servizi

Autore	Antonio Ruocco
Contesto	Esercitazione di laboratorio su pfSense, Kali Linux e Metasploitable
Oggetto	Blocco dell'accesso a DVWA da Kali e oscuramento del servizio rispetto alla scansione
Data esercitazione	20/03/2026

Sintesi esecutiva

L'attività ha previsto la creazione di una seconda rete LAN in VirtualBox, la configurazione di pfSense come punto di interconnessione e controllo, l'assegnazione statica degli IP a Kali Linux e Metasploitable e la definizione di regole firewall mirate. L'obiettivo era impedire a Kali l'accesso a DVWA e ridurre la visibilità del servizio web in fase di scansione rapida.



1. Obiettivo e impostazione metodologica

L'esercitazione è stata affrontata con una logica difensiva progressiva: prima è stata definita la topologia, poi verificata la connettività di base e solo dopo sono state applicate le regole restrittive. Questo approccio consente di separare i problemi di addressing e routing da quelli di filtering.

Decisioni progettuali adottate

- segmentare i sistemi in due subnet differenti per forzare il passaggio del traffico su pfSense;
- assegnare indirizzi statici e disattivare il DHCP per mantenere controllo e prevedibilità;
- introdurre prima una baseline funzionante e solo dopo applicare il blocco mirato;
- limitare la policy ai servizi da proteggere: HTTP/80.

2. Ambiente di laboratorio e topologia logica

La soluzione è stata realizzata in ambiente virtualizzato. pfSense ha svolto il ruolo di firewall/router tra due reti interne separate; Kali Linux è stato posizionato sulla LAN primaria, mentre Metasploitable è stato collocato su una seconda LAN dedicata.

```
Topologia logica


WAN  -> pfSense em0  -> 192.168.0.1
LAN1 -> pfSense em1  -> 192.168.1.1/24 -> Kali Linux       192.168.1.10
LAN2 -> pfSense OPT1 -> 192.168.2.1/24 -> Metasploitable  192.168.2.10
```

Configurazioni principali

Componente	Ruolo	Configurazione rilevante
pfSense	Firewall / Router	WAN em0 192.168.0.1; LAN em1 192.168.1.1; OPT1 192.168.2.1
Kali Linux	Client sorgente	IP statico 192.168.1.10; default gateway 192.168.1.1
Metasploitable	Host target / servizi	IP statico 192.168.2.10; default gateway 192.168.2.1; DVWA su HTTP

3. Implementazione tecnica

3.1 Creazione della seconda rete interna

In VirtualBox è stata creata una nuova rete interna, identificata come intnet2, destinata a ospitare la seconda LAN. La scelta riflette una corretta pratica di segmentazione: client e target vengono separati su subnet distinte e il traffico converge su un punto di controllo centralizzato.

3.2 Assegnazione delle interfacce in pfSense

Da console pfSense è stata eseguita l'assegnazione manuale delle interfacce tramite il menu "Assign Interfaces". Le interfacce sono state associate a WAN, LAN e OPT1; in questa fase il DHCP è stato disattivato per mantenere una configurazione statica più prevedibile.

3.3 Configurazione statica degli host

Kali Linux è stato configurato con indirizzo 192.168.1.10 sulla LAN 192.168.1.0/24, mentre Metasploitable con indirizzo 192.168.2.10 sulla LAN 192.168.2.0/24. L'uso di IP statici rende le regole firewall deterministiche.

3.4 Verifica preliminare della connettività

Prima del blocco mirato, è stata verificata la comunicazione verso le rispettive interfacce LAN del firewall. Dalla GUI è emersa l'assenza iniziale di regole permissive sulla seconda rete; di conseguenza è stata introdotta una regola PASS temporanea per validare il corretto transito del traffico di test.

3.5 Abilitazione del routing tra le subnet

Per consentire la comunicazione inter-LAN sono stati impostati i gateway di default sugli endpoint: "sudo route add default gw 192.168.1.1" su Kali e "sudo route add default gw 192.168.2.1" su Metasploitable. Questo passaggio ha permesso al traffico di uscire dalla subnet locale e raggiungere l'altra rete tramite pfSense.

3.6 Validazione applicativa prima del blocco

Una volta confermata la connettività IP, è stato verificato che Kali potesse raggiungere l'interfaccia web di Metasploitable e la pagina DVWA. La prova ha confermato che il percorso di rete era corretto e che il servizio HTTP risultava esposto prima della policy restrittiva.

Punto di controllo chiave

La soluzione è stata costruita partendo da una baseline funzionante: connettività locale, routing, test applicativo e solo infine hardening. È una sequenza corretta di troubleshooting professionale.

4. Regola firewall per bloccare DVWA

Dalla GUI di pfSense, nella sezione Firewall > Rules > LAN1, è stata creata una regola di tipo BLOCK sul traffico TCP diretto al servizio HTTP della macchina Metasploitable. La regola è stata costruita in modo mirato: sorgente Kali, destinazione 192.168.2.10, porta di destinazione 80.

Campo regola	Valore impostato / finalità
Action	BLOCK - negazione esplicita del traffico
Interface	LAN1 - punto d'ingresso del traffico proveniente da Kali
Protocol	TCP - focalizzazione sul servizio web
Source	Host Kali Linux (192.168.1.10)
Destination	Metasploitable (192.168.2.10)
Destination Port	80/HTTP - servizio DVWA

5. Verifiche e risultati ottenuti

La configurazione è stata validata con un doppio approccio: test funzionale da browser e test di enumerazione dei servizi da riga di comando. Dopo l'introduzione della regola, la pagina DVWA non è più risultata raggiungibile da Kali; una scansione rapida con "nmap -F" ha mostrato la porta 80 come "filtered", evidenziando l'intervento del firewall.

Verifica	Prima della regola	Dopo la regola	Esito
Accesso browser a DVWA	Consentito	Negato	Obiettivo raggiunto
Scansione rapida porta 80	Servizio visibile	Porta "filtered"	Visibilità ridotta
Comunicazione inter-LAN	Abilitata dopo routing	Controllata da policy	Traffico governato

6. Valutazione tecnica e considerazioni finali

La soluzione dimostra una comprensione corretta di segmentazione, routing inter-subnet e filtering stateful. L'elemento più solido del lavoro non è soltanto la regola finale, ma il processo seguito per arrivarci: creazione della topologia, addressing coerente, verifica controllata, abilitazione del routing e applicazione delle restrizioni mirate.

Dal punto di vista della sicurezza, l'applicazione DVWA non è più direttamente accessibile dal client sorgente e il servizio HTTP non risulta immediatamente interpretabile attraverso una scansione rapida.